QYNTIV

CHECKLIST · PROTECTION DES DONNÉES

Vos outils sont-ils conformes *à la nLPD ?*

20 questions pour faire le point en 10 minutes. Pour toutes les entreprises suisses, quel que soit leur secteur.

PAR EMMANUEL PERCHERON · FONDATEUR DE QYNTIV · FRIBOURG, SUISSE

AVANT DE COMMENCER

Depuis septembre 2023, *la loi a changé.*

La nouvelle loi fédérale sur la protection des données (nLPD) est en vigueur depuis le **1er septembre 2023**. Elle concerne toutes les entreprises qui traitent des données personnelles : celles de leurs clients, de leurs employés, de leurs fournisseurs. Autrement dit, presque toutes.

Les personnes responsables risquent des amendes **jusqu'à 250 000 CHF** en cas de violation intentionnelle de certaines obligations. Mais la bonne nouvelle, c'est que la plupart des règles relèvent du bon sens : savoir ce que l'on garde, le protéger, et le dire clairement.

Cette checklist rassemble **vingt questions**, réparties en cinq thèmes. Cochez celles auxquelles vous pouvez répondre oui, puis comptez vos points à la page 5.

Les mots à connaître

Donnée personnelle
Toute information sur une personne identifiable : nom, e-mail, numéro AVS, photo, adresse IP.

Donnée sensible
Santé, opinions religieuses ou politiques, poursuites pénales, aide sociale, données génétiques ou biométriques.

Sous-traitant
Un prestataire qui traite des données pour vous : hébergeur, logiciel en ligne, fiduciaire.

PFPDT
Le Préposé fédéral à la protection des données et à la transparence, l'autorité de surveillance.

LA CHECKLIST

A. Vos données

- [ ] 1. Vous savez quelles données personnelles votre entreprise collecte, et où elles sont stockées.
  Un simple inventaire suffit à la plupart des PME. Le registre des activités de traitement est obligatoire à partir de 250 collaborateurs, ou pour certains traitements à risque.

- [ ] 2. Vous avez repéré les données sensibles que vous traitez.
  Santé, opinions, poursuites ou sanctions pénales, mesures d'aide sociale, données biométriques : elles exigent une protection renforcée.

- [ ] 3. Vous ne collectez que ce qui est vraiment nécessaire.
  C'est le principe de proportionnalité : chaque information demandée doit servir un but précis.

- [ ] 4. Vous savez combien de temps vous gardez chaque type de données, et vous effacez ce qui ne sert plus.
  Les durées légales priment (par exemple 10 ans pour la comptabilité). Le reste ne se garde pas indéfiniment.

B. Informer

- [ ] 5. Votre site affiche une déclaration de protection des données à jour.
  Elle dit qui traite les données, lesquelles, pourquoi, avec quels prestataires, et comment exercer ses droits.

- [ ] 6. Vos formulaires (contact, devis, inscription) indiquent à quoi servent les informations demandées.
  Une phrase claire près du bouton d'envoi, avec un lien vers la déclaration, suffit souvent.

- [ ] 7. Les outils de mesure d'audience et les cookies sont mentionnés dans votre déclaration.
  Google Analytics, pixels publicitaires, cartes intégrées : ils transmettent souvent des données à l'étranger.

- [ ] 8. Vos employés savent quelles données les concernent et pourquoi elles sont traitées.
  Salaires, absences, évaluations : eux aussi ont droit à une information claire.

C. Vos prestataires

- [ ] 9. Vous avez la liste des outils et services en ligne qui traitent vos données.
  Messagerie, stockage en ligne, comptabilité, gestion client, agenda, formulaires, sauvegardes.
- [ ] 10. Un contrat ou des conditions encadrent chaque prestataire qui traite des données pour vous.
  La loi parle de sous-traitance : le prestataire ne peut utiliser vos données que pour vous, et doit les protéger.
- [ ] 11. Vous savez dans quel pays vos données sont stockées.
  En Suisse, dans l'Union européenne, aux États-Unis ? La réponse se trouve en général dans les conditions du service.
- [ ] 12. Pour les pays qui ne figurent pas sur la liste du Conseil fédéral, des garanties sont en place.
  Par exemple, pour les États-Unis : un prestataire certifié Swiss-U.S. Data Privacy Framework, ou des clauses contractuelles reconnues.

D. Sécurité

- [ ] 13. Chaque personne a son propre accès, avec un mot de passe solide et la double authentification quand c'est possible.
  Un compte partagé ne permet pas de savoir qui a fait quoi, et il ne se ferme jamais vraiment.
- [ ] 14. Les ordinateurs et les téléphones sont verrouillés, chiffrés et tenus à jour.
  Un portable volé ne doit rien révéler, et les mises à jour bouchent les failles connues.
- [ ] 15. Les sauvegardes sont régulières, protégées, et vous avez déjà testé une restauration.
  Une sauvegarde jamais testée est une promesse, pas une sauvegarde.
- [ ] 16. Les accès d'un collaborateur qui part sont retirés le jour même.
  Messagerie, partages, logiciels métier, téléphones professionnels : une liste aide à ne rien oublier.

E. Si quelque chose arrive

- [ ] 17. Vous savez répondre à une demande d'accès d'un client ou d'un employé dans les 30 jours.
  Toute personne peut demander quelles données vous détenez sur elle. Savoir où chercher fait gagner un temps précieux.

- [ ] 18. Vous savez quoi faire en cas de fuite de données.
  Si elle présente un risque élevé pour les personnes concernées, elle doit être annoncée au PFPDT dans les meilleurs délais.

- [ ] 19. Une personne est clairement responsable de la protection des données dans l'entreprise.
  Un conseiller à la protection des données est facultatif, mais quelqu'un doit savoir qui fait quoi.

- [ ] 20. Votre équipe est sensibilisée aux risques courants.
  Faux e-mails (hameçonnage), mots de passe, clés USB, documents imprimés laissés sur un bureau.

= Votre résultat

16 à 20 oui

Vous êtes sur la bonne voie. Gardez le rythme : relisez cette liste une fois par an.

10 à 15 oui

Quelques points à renforcer. Commencez par la sécurité (thème D) : c'est là que les incidents arrivent.

Moins de 10

C'est une priorité. Faites le point avec votre fiduciaire ou un spécialiste, thème par thème.

PASSER À L'ACTION

Et *maintenant ?*

1. **Commencez par les cases vides du thème D**, la sécurité : ce sont souvent les plus rapides à corriger, et les plus importantes.

2. **Faites la liste de vos outils** (thème C), puis vérifiez pour chacun où sont vos données et ce que dit son contrat.

3. **Mettez votre déclaration à jour** (thème B) : c'est ce que vos clients voient en premier.

Des logiciels conformes *dès la conception.*

Chez Qyntiv, la protection des données n'est pas une option : vos données restent chez vous ou en Suisse, les accès sont maîtrisés, et chaque outil est pensé pour respecter la nLPD. Parlons de vos besoins en 30 minutes, gratuitement et sans engagement.

RÉSERVER SUR QYNTIV.COM/SUR-MESURE



EMMANUEL PERCHERON

Fondateur de Qyntiv, studio suisse de logiciels sur mesure basé à Fribourg.
qyntiv.com

Cette checklist donne des repères généraux et ne remplace pas un avis juridique. Version de novembre 2026.